Readiness report

Repository: me2resh/ddd-sam-example · Commit `36c3ed0` · Audit date: 10 November 2026

This is a real readiness audit of a public sample app. The app is a patient appointments system: a React frontend, four serverless backends and a workflow worker. We publish this report as an example. Each finding names the file and the line that show it.

Verdict

No-go

Four of the ten areas fail, and the audit found two critical security gaps. Do not release this app to users before you fix the blocking items.

Top actions

1. Add authentication to all patient appointment APIs and to the frontend.
2. Update the dependencies that have critical vulnerabilities, starting with protobufjs.
3. Add a health endpoint and an error tracking service to each API.

Gaps by area and severity

Area	Verdict	Critical	High	Medium	Low
Security	Fail	2	1	4	2
Accessibility	Warn	0	0	1	2
Compliance	Fail	0	1	3	0
Analytics	Fail	0	1	0	0
Search	Warn	0	0	1	2
AI search	Warn	0	0	0	2
Performance	Pass	0	0	0	0
Monitoring	Fail	0	2	2	1
Documentation	Warn	0	0	2	3
Behaviour quality	Warn	0	0	1	1

Gaps by area

Each area gets one verdict: pass, warn or fail. Under each verdict, the report lists the gaps from the most severe to the least severe.

Security

Fail

The appointment APIs have no authentication, and six dependencies have critical advisories.

CRITICAL

The appointment APIs have no authentication. Anyone with the API address can read the appointments of a patient. The frontend has no sign-in, and its committed .env file holds the deployed API address.

`appointments-app-backend/template.yaml:24-29`

`appointments-app-backend-java/template.yaml:70-75`

`appointments-app-backend-python-pip/template.yaml:23-28, 39-43`

`appointments-app-frontend-react/src/components/PatientAppointments.tsx:37-52`

`appointments-app-frontend-react/.env:5`

CRITICAL

Six dependencies have critical advisories. The frontend has five: @babel/traverse, form-data, proxy-addr, shell-quote and websocket-driver. The workflow worker has protobufjs. All six are indirect dependencies.

`npm audit --package-lock-only, 10 November 2026`

`appointments-app-frontend-react/package-lock.json`

`patients-appointments-temporal/package-lock.json`

HIGH

The three Node lockfiles have 53 high advisories: 31 in the frontend, 14 in the workflow worker and 8 in the TypeScript backend. In the worker, nanoid and nodemon are direct dependencies.

`npm audit --package-lock-only, 10 November 2026`

`patients-appointments-temporal/package.json`

MEDIUM

Error responses send the internal error message to the caller. An attacker can learn about the code and the data store from these messages.

`appointments-app-backend/src/command/lambda/patient-appointments.ts:43-49`

`appointments-app-backend-java/src/main/java/command/lambda/PatientAppointmentDynamoDBHandler.java:65-69`

`appointments-app-backend-python-pip/src/command/lambda/patient_appointment.py:35-38`

MEDIUM

The CORS headers allow every origin. The TypeScript backend also allows every header and every method.

`appointments-app-backend/src/command/lambda/patient-appointments.ts:9-13`

`appointments-app-backend-java/src/main/java/command/lambda/PatientAppointmentDynamoDBHandler.java:73-78`

MEDIUM The deploy workflows use long-lived cloud access keys. A short-lived role for each run gives less exposure if a key leaks.

`appointments-app-backend/.github/workflows/deploy-ci.yml:30-31`

`appointments-app-backend/.github/workflows/deploy-dev-staging.yml:30-31`

`appointments-app-backend/.github/workflows/deploy-production.yml:28-29`

MEDIUM Three templates set runtimes that are past their end of life: Node.js 18 and Python 3.9. These runtimes get no more security fixes.

`appointments-app-backend/template.yaml:21`

`appointments-app-backend-python-pip/template.yaml:12`

`appointments-app-backend-python-poetry/template.yaml:12`

LOW The workflow worker connects to a fixed local address without TLS.

`patients-appointments-temporal/src/worker.ts:7-9`

LOW The patient and appointment tables have no point-in-time recovery. After a bad write, you cannot restore the data to an earlier time.

`appointments-app-backend-java/template.yaml:21-59`

Accessibility

Warn

The page does not reflow on a narrow screen. Status messages are silent for screen readers.

MEDIUM The main container has a fixed width of 800 px. At 320 px the page scrolls sideways (WCAG 2.2, criterion 1.4.10, Reflow).

`appointments-app-frontend-react/src/styles/patient-appointments.css:10-12`

LOW The error message and the loading message have no live region. A screen reader does not announce them.

`appointments-app-frontend-react/src/components/PatientAppointments.tsx:53-55`

LOW The page has no main landmark, and the results table has no caption.

`appointments-app-frontend-react/src/components/PatientAppointments.tsx:38, 57`

Compliance

Fail

The app shows patient health data, but it has no privacy notice.

HIGH The app shows patient health data, but it has no privacy notice. The frontend has no privacy page and no link to one.

`appointments-app-frontend-react/public/`

`appointments-app-frontend-react/src/`

MEDIUM The app has no terms of use.

`appointments-app-frontend-react/public/`

`appointments-app-frontend-react/src/`

MEDIUM No API deletes the data of a patient. The templates define read routes only.

`appointments-app-backend/template.yaml:28-29`

`appointments-app-backend-java/template.yaml:74-75`

MEDIUM The logs hold patient identifiers. The TypeScript handler also logs the full request event.

`appointments-app-backend/src/command/lambda/patient-appointments.ts:16, 33`

`appointments-app-backend-java/src/main/java/command/lambda/PatientAppointmentDynamoDBHandler.java:54`

Analytics

Fail

The user-facing app records no use at all.

HIGH The frontend has no analytics tool and records no events. reportWebVitals() runs without a handler, so it measures nothing.

`appointments-app-frontend-react/src/index.tsx:19`

`appointments-app-frontend-react/src/reportWebVitals.ts:3-4`

Search

Warn

The page keeps the default title and description of the project template.

MEDIUM The page title is "React App", and the description is the template default.

`appointments-app-frontend-react/public/index.html:8-11, 27`

LOW The page has no Open Graph tags.

`appointments-app-frontend-react/public/index.html:3-28`

LOW The app has no sitemap.xml, and robots.txt names no sitemap.

`appointments-app-frontend-react/public/robots.txt:1-3`

AI search

Warn

Coding agents and AI search tools get no guide to the repository.

LOW The repository has no AGENTS.md file at its root.

`(repository root)`

LOW The frontend has no llms.txt file.

`appointments-app-frontend-react/public/`

Performance

Pass

No gaps found. The frontend is one small component, it loads web-vitals on demand, and its two images are under 10 KB.

Limit: the audit did not build the frontend, so it did not measure the bundle size. It read the source and the public files only.

Monitoring

Fail

No API has a health endpoint, and no service reports errors.

HIGH — No API has a health endpoint. Each template defines the appointment routes only.

`appointments-app-backend/template.yaml:24-29`

`appointments-app-backend-java/template.yaml:70-75`

HIGH — No component reports errors to an error tracking service.

`appointments-app-backend/package.json`

`appointments-app-frontend-react/package.json`

`appointments-app-backend-java/pom.xml`

MEDIUM — The TypeScript logger writes log files next to the code. A serverless function can write only to /tmp, so these writes fail.

`appointments-app-backend/src/utils/logger.ts:9-10`

MEDIUM — Only the TypeScript template turns on application monitoring. The Java and Python stacks have no alarms, and no stack has a runbook.

`appointments-app-backend/template.yaml:49-58`

LOW — The Java handler logs the placeholder lines "A" to "F".

`appointments-app-backend-java/src/main/java/command/lambda/PatientAppointmentDynamoDBHandler.java:33-53`

Documentation

Warn

The root README is out of date, and the APIs have no reference.

MEDIUM — The root README changed last on 12 July 2024. The code changed until 22 July 2025. The README does not name the two Python backends.

`Readme.md:12-17`

`git log -- Readme.md`

MEDIUM — The APIs have no reference, for example an OpenAPI file.

`(repository)`

LOW — The README links to the folder appointments-app-frontend. The folder is appointments-app-frontend-react.

`Readme.md:16`

LOW The repository has no changelog.

`(repository root)`

LOW The stack output shows the wrong URL path, /Prod/hello/.

`appointments-app-backend/template.yaml:65`

Behaviour quality

▢ Warn

The tests exist, but no CI runs them.

MEDIUM The CI workflows never run. They are in a subfolder, and GitHub reads workflows only from .github/workflows at the root. The repository has no workflow runs.

`appointments-app-backend/.github/workflows/`

`GitHub Actions API: 0 workflows, 0 runs`

LOW No mutation report exists, and no mutation testing tool is set up. The audit cannot say how well the tests constrain behaviour.

`(repository)`

How we ran this audit

1. We made a read-only copy of the public repository at commit `36c3ed0`.
2. We checked the ten areas of the readiness audit. For each area, we read the source, the templates, the configuration and the public files.
3. We ran `npm audit --package-lock-only` on the three Node lockfiles and `pip-audit` on the Python requirements.
4. We read the workflow state of the repository from the GitHub API.
5. We gave each area a verdict, counted the gaps by severity and chose the top actions.

Limits of this audit:

- We did not build, deploy or run the app. We did not test it in a browser.
- Advisory counts change each day. The counts in this report are for 10 November 2026.
- The audit is a quick check of each area. A deeper audit of one area can find more gaps.

The verdict follows these rules:

Verdict	When
Go	No area fails. The report lists any warnings to fix before the next milestone.
Conditional go	One or two areas fail. Fix the blocking items before you release.
No-go	Three or more areas fail, or the audit finds a critical security gap.

ApexYard readiness report. Sample: a real audit of the public repository me2resh/ddd-sam-example, published as an example. Report template: apexyard.ai/docs/readiness/report-template